Lab Assignment 3

Stepan Shkrobak

Dr. Michael Bartolacci

IST 894, Section 001: Capstone Experience,

15 February 2026

1. Table of Contents

1. Table of Contents....2
1. General Context....3
2. Technical Context....4
3. Screenshots....6
SCADA - Attacking the Infrastructure....6
Firewall Rules for SCADA....11
4. References....15

1. General Context

Attacking the Infrastructure Lab covered endpoint compromise, social engineering, and privilege escalation. I had us simulate a phishing scenario in which a malicious software package was installed, resulting in remote command execution and overall system compromise. It showed the risks of trusting email attachments, improper validation of software sources, weak privilege separation, and misconfigured administrative access controls. Also showed how attackers try to establish persistence along with escalating privileges. Overall shows the weak link in security, which is the human element in cybersecurity, and the operational consequences of insufficient access control, user awareness, and monitoring.

The Firewall Rules for SCADA focused on network layer defenses and traffic control. It involved applying firewall logic to filter and log specific types of traffic, particularly to protocols such as Modbus. It covered more specifically packet filtering, rule chaining, selective logging, and protocol-aware filtering. It also introduced honeypot deployment concepts, showing how simulated ICS devices can be used to observe and analyze potentially malicious activity. Overall, we see the importance of protocol-level inspection and monitoring in protecting tech environments.

The labs together show how modern cybersecurity strategy must cover both the technical as well as the human factors in regard to risk management. NIST Special Publication 800-82 emphasizes that ICS environments demand tailored defensive mechanisms, including network segmentation, protocol-aware monitoring, and strict access control to reduce the attack surface and limit operational disruption (Stouffer et al., 2015). Research on the human dimension of cybersecurity consistently also shows

that social engineering and phishing remain among the most effective initial access vectors, reinforcing the need for user awareness, least-privilege enforcement, and monitoring of administrative activity (Hadnagy, 2018).

2. Technical Context

The Attacking the Infrastructure lab covered endpoint compromise, along with social engineering and privilege escalation. In the lab, a simulated phishing attack was performed to acquire initial access, which resulted in remote command execution and full system compromise through a reverse shell. The lab emphasized weaknesses in software trust validation, insufficient privilege separation, and overly permissive administrative controls. It reinforced how attackers pivot from user-level access to elevated privileges when least-privilege principles are not enforced. This aligns with findings from the Verizon Data Breach Investigations Report, which consistently identifies phishing and credential abuse as leading breach vectors and highlights privilege misuse as a major impact multiplier in successful compromises (Verizon, 2023).

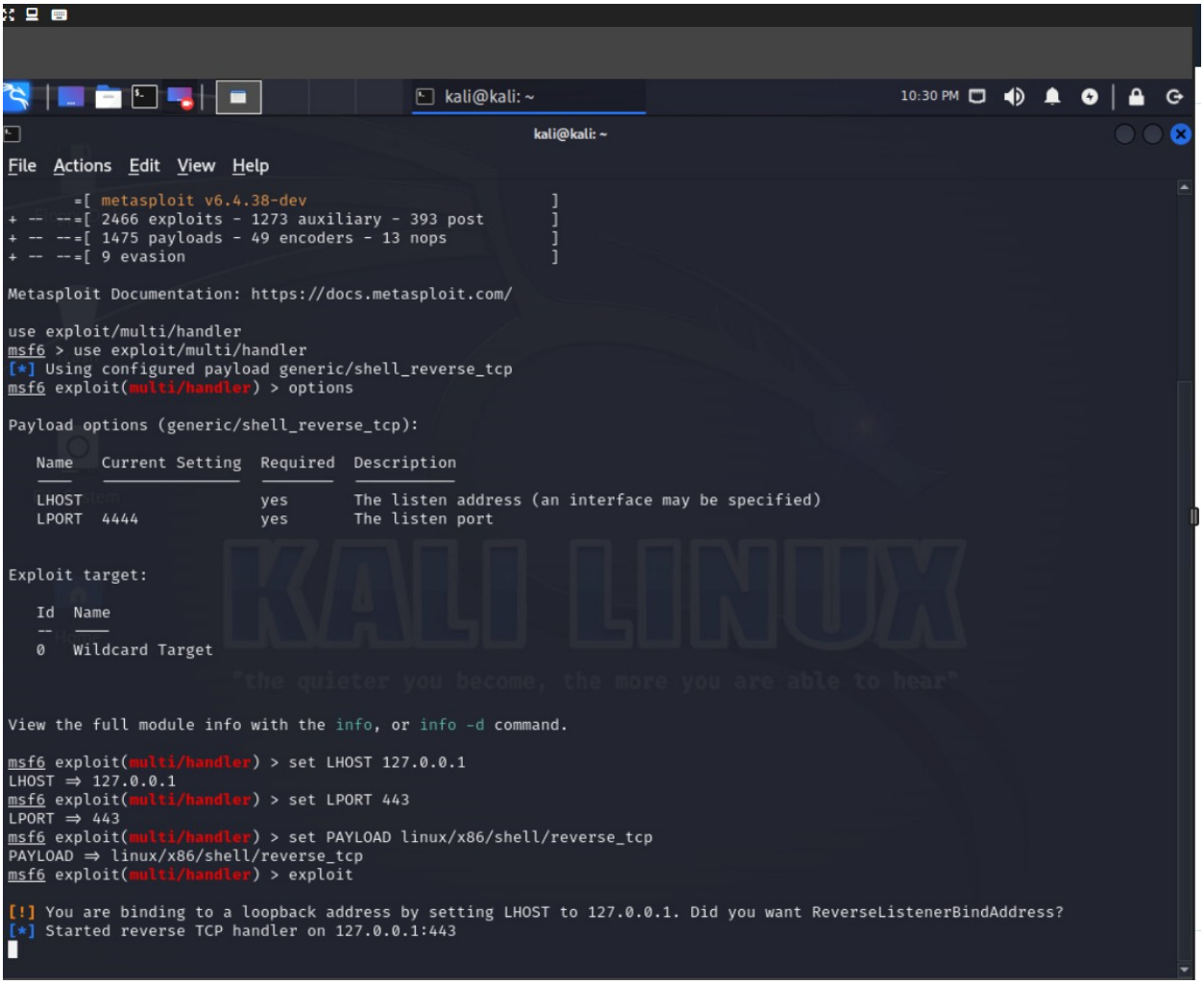
The Firewall Rules for SCADA lab focused on network-layer defense within an ICS context. It required applying packet filtering, custom chain logic, selective logging, and protocol-aware inspection rather than simple port-based filtering. The use of payload-level matching demonstrated how defenders can implement granular controls tailored to industrial protocol behavior. Because ICS protocols like Modbus lack authentication and integrity protections, filtering and segmentation become primary

defensive controls. The lab also showed the honeypot deployment concepts, illustrating passive monitoring and intelligence collection in operational technology environments. These practices align with NIST SP 800-82, which emphasizes segmentation, boundary protection, and protocol-aware monitoring as foundational ICS security controls (Stouffer et al., 2015).

Together, the labs show that effective cybersecurity requires coordinated host-level and network-level defenses. The endpoint-focused lab demonstrated the attack lifecycle progression from initial access to privilege escalation and persistence, while the SCADA firewall lab emphasized preventative and detective controls at the network boundary. Combined, they reflect a defense-in-depth strategy integrating technical safeguards with human risk management. For ICS environments specifically, this layered approach is critical because operational disruption carries safety and availability consequences beyond traditional IT systems (Stouffer et al., 2015).

3. Screenshots

SCADA - Attacking the Infrastructure



Starting Metasploit Framework

```
kali@kali: ~
File  Actions  Edit  View  Help
kali@kali:~$ sudo service postfix start
[sudo] password for kali:
kali@kali:~$ echo "This utility is very useful. Download from <a href="http://192.168.1.100/digitemp.deb">here</a>." | mutt
 e "set content_type=text/html" s "Digitemp Download"  root@192.168.1.100
kali@kali:~$ mutt
1 kept, 0 deleted.
kali@kali:~$ mutt
1 kept, 0 deleted.ery useful. Downl
kali@kali:~$ echo "This utility is very useful. Download from <a href="http://192.168.1.100/digitemp.deb">here</a>." | mutt
 e "set content_type=text/html" s "Digitemp Download"  root@192.168.1.100echo "This utility is very useful. Download from <
a href="http://192.168.1.100/digitemp.deb">here</a>." | mutt e "set content_type=text/html" s "Digitemp Download"  root@192
.168.1.100echo "This utility is very useful. Download from <a href="http://192.168.1.100/digitemp.deb">here</a>." | mutt e
"set content_type=text/html" s "Digitemp Download"  root@192.168.1.100^C
kali@kali:~$
```

Sending Phishing Email

```
File  Actions  Edit  View  Help
kali@kali:~$ sudo service postfix start
[sudo] password for kali:
kali@kali:~$ echo "This utility is very useful. Download from <a href="http://192.168.1.100/digitemp.deb">here</a>." | mutt
 e "set content_type=text/html" s "Digitemp Download"  root@192.168.1.100
kali@kali:~$ mutt
1 kept, 0 deleted.
kali@kali:~$ mutt
1 kept, 0 deleted.ery useful. Downl
kali@kali:~$ echo "This utility is very useful. Download from <a href="http://192.168.1.100/digitemp.deb">here</a>." | mutt
 e "set content_type=text/html" s "Digitemp Download"  root@192.168.1.100echo "This utility is very useful. Download from <
a href="http://192.168.1.100/digitemp.deb">here</a>." | mutt e "set content_type=text/html" s "Digitemp Download"  root@192
.168.1.100echo "This utility is very useful. Download from <a href="http://192.168.1.100/digitemp.deb">here</a>." | mutt e
"set content_type=text/html" s "Digitemp Download"  root@192.168.1.100^C
kali@kali:~$ mutt
Executing: /etc/urlview/url_handler.sh 'http://192.168.1.100/digitemp.deb' ...
Executing: /etc/urlview/url_handler.sh 'http://192.168.1.100/digitemp.deb' ...
Press any key to continue ...
Mailbox is unchanged.
kali@kali:~$ cd ~/Downloads
kali@kali:~/Downloads$ sudo dpkg -i digitemp.deb
Selecting previously unselected package digitemp.
(Reading database ... 367963 files and directories currently installed.)
Preparing to unpack digitemp.deb ...
Unpacking digitemp (3.7.2-1) ...
Setting up digitemp (3.7.2-1) ...
Processing triggers for man-db (2.12.0-1) ...
kali@kali:~/Downloads$
```

Reading Email

```
File  Actions  Edit  View  Help
                -O"counter format string"      See description below
                -o 2                          Output format for logfile
                -o"output format string"      See description below
                -H"Humidity format string"    See description below

Logfile formats:  1 = One line per sensor, time, C, F (default)
                  2 = One line per sample, elapsed time, temperature in C
                  3 = Same as #2, except temperature is in F
                  4 = Same as #2, except elapsed time since (1970-01-01 00:00:00)
                  5 = Same as #4, except temperature is in F
        #2 and #3 have the data separated by tabs, suitable for import
        into a spreadsheet or other graphing software.

        The format string uses strftime tokens plus 5 special ones for
        digitemp - %s for sensor #, %C for centigrade, %F for fahrenheit,
        %R to output the hex serial number, and %N for seconds since Epoch.
        The case of the token is important! The default format string is:
        "%b %d %H:%M:%S Sensor %s C: %.2C F: %.2F" which gives you an
        output of: May 24 21:25:43 Sensor 0 C: 23.66 F: 74.59

        The counter format string has 2 special specifiers:
        %n is the counter # and %C is the count in decimal.
        The humidity format uses %h for the humidity in percent

        The logfile may contain strftime pattern to format the filename
kali@kali:~/Downloads$ su - hacker
Password:
su: Authentication failure
kali@kali:~/Downloads$ su - hacker
Password:
su: warning: cannot change directory to /home/hacker: No such file or directory
┌──(Message from Kali developers)
│
│ This is a minimal installation of Kali Linux, you likely
│ want to install supplementary tools. Learn how:
│ ⇒ https://www.kali.org/docs/troubleshooting/common-minimum-setup/
│
└──(Run: "touch ~/.hushlogin" to hide this message)
$ id
uid=1001(hacker) gid=1001(hacker) groups=1001(hacker)
$
```

Adding New User

kali@kali: ~/Downloads

File Actions Edit View Help

```
tss:*:18502:0:99999:7:::
strongswan:*:18502:0:99999:7:::
ntp:*:18502:0:99999:7:::
messagebus:*:18502:0:99999:7:::
redsocks:!:18502:0:99999:7:::
rwhod:*:18502:0:99999:7:::
iodine:*:18502:0:99999:7:::
miredo:*:18502:0:99999:7:::
usbmux:*:18502:0:99999:7:::
tcpdump:*:18502:0:99999:7:::
rtkit:*:18502:0:99999:7:::
_rpc:*:18502:0:99999:7:::
Debian-snmp:!:18502:0:99999:7:::
statd:*:18502:0:99999:7:::
postgres:*:18502:0:99999:7:::
stunnel4:!:18502:0:99999:7:::
sshd:*:18502:0:99999:7:::
sslh:!:18502:0:99999:7:::
avahi:*:18502:0:99999:7:::
nm-openvpn:*:18502:0:99999:7:::
nm-openconnect:*:18502:0:99999:7:::
pulse:*:18502:0:99999:7:::
saned:*:18502:0:99999:7:::
inetsim:*:18502:0:99999:7:::
colord:*:18502:0:99999:7:::
geoclue:*:18502:0:99999:7:::
lightdm:*:18502:0:99999:7:::
king-phisher:*:18502:0:99999:7:::
kali:$6$BFekYFBfJXJOb2vM$P0xJ/eGUrT4bAiLGmbxEDrvswCvngbaTMEVM1ZXkW.Rx1ZLeIA.yjTNuX1Nqq22iHbJFx7PRySMaOKOFM.Yjt0:18513:0:999
99:7:::
systemd-coredump:!*:18502::::::
xrdp:!:18513:0:99999:7:::
redis:!:19312::::::
ntpsec:!:19312::::::
polkitd:!*:19312::::::
postfix:!:20101::::::
dovecot:!:20101::::::
dovenull:!:20101::::::
ftp:!:20101::::::
hacker:$y$j9T$H06w.rwfenoIj4mCRFV9L1$JyDwOWr.DrFhR7joXEiQ2qHMSe0F/mZlOyw2bjJNlO4:20500:0:99999:7:::
$
```

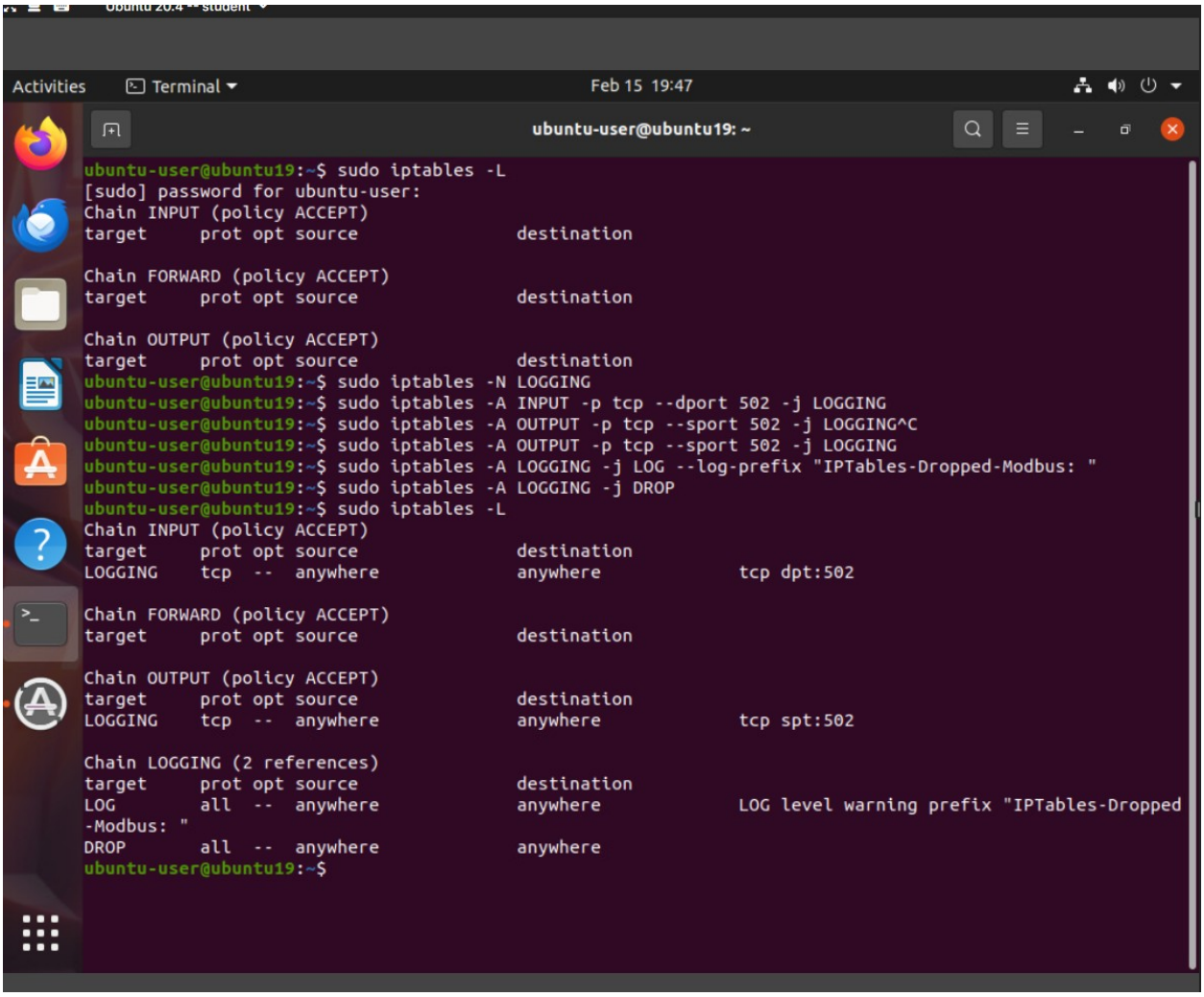
Elevating User Privileges

SCADA - Attacking the Infrastructure

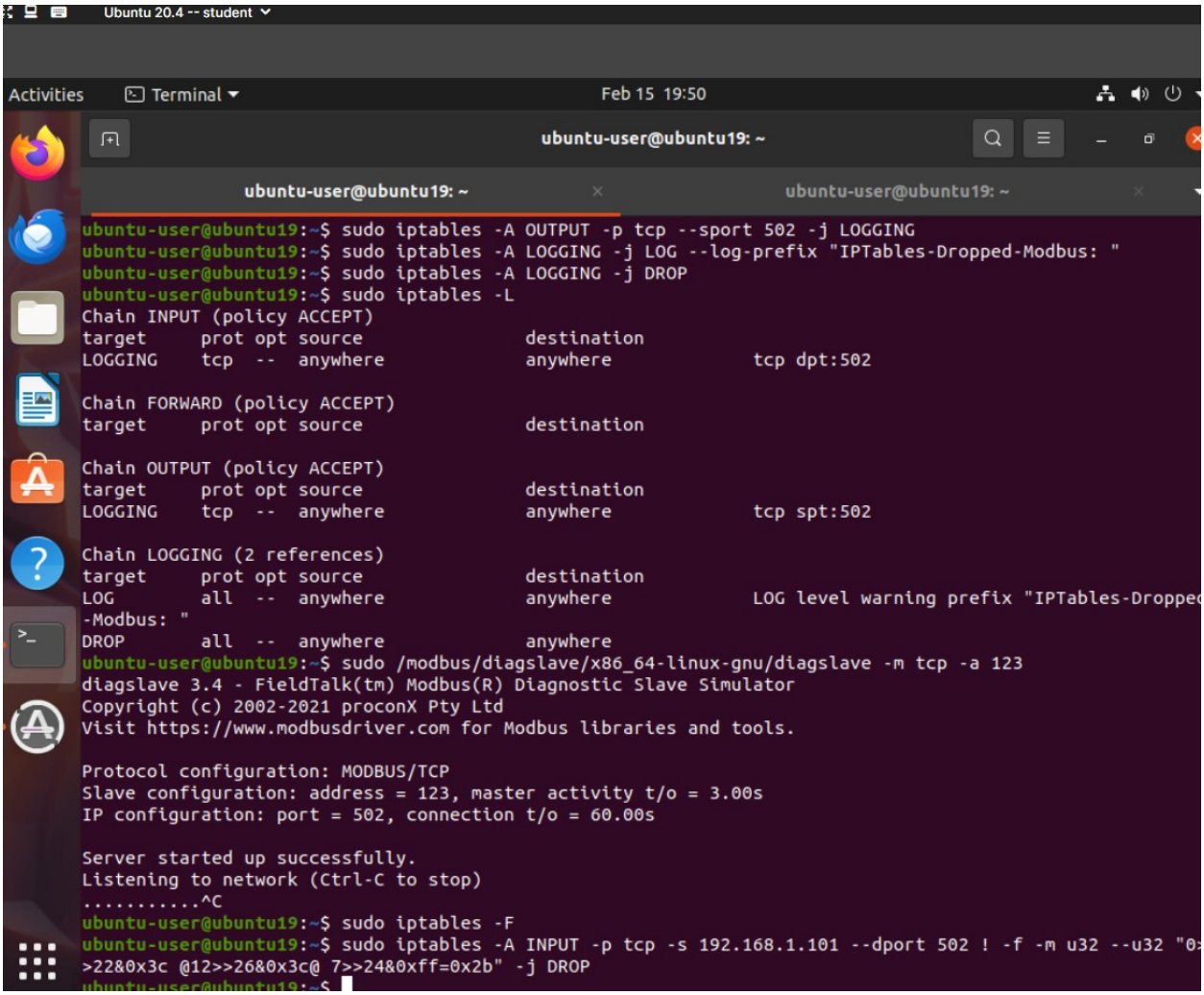
Lab · 1 hour

Learn about compromising a system as you practice in the Scada Cyber Range.

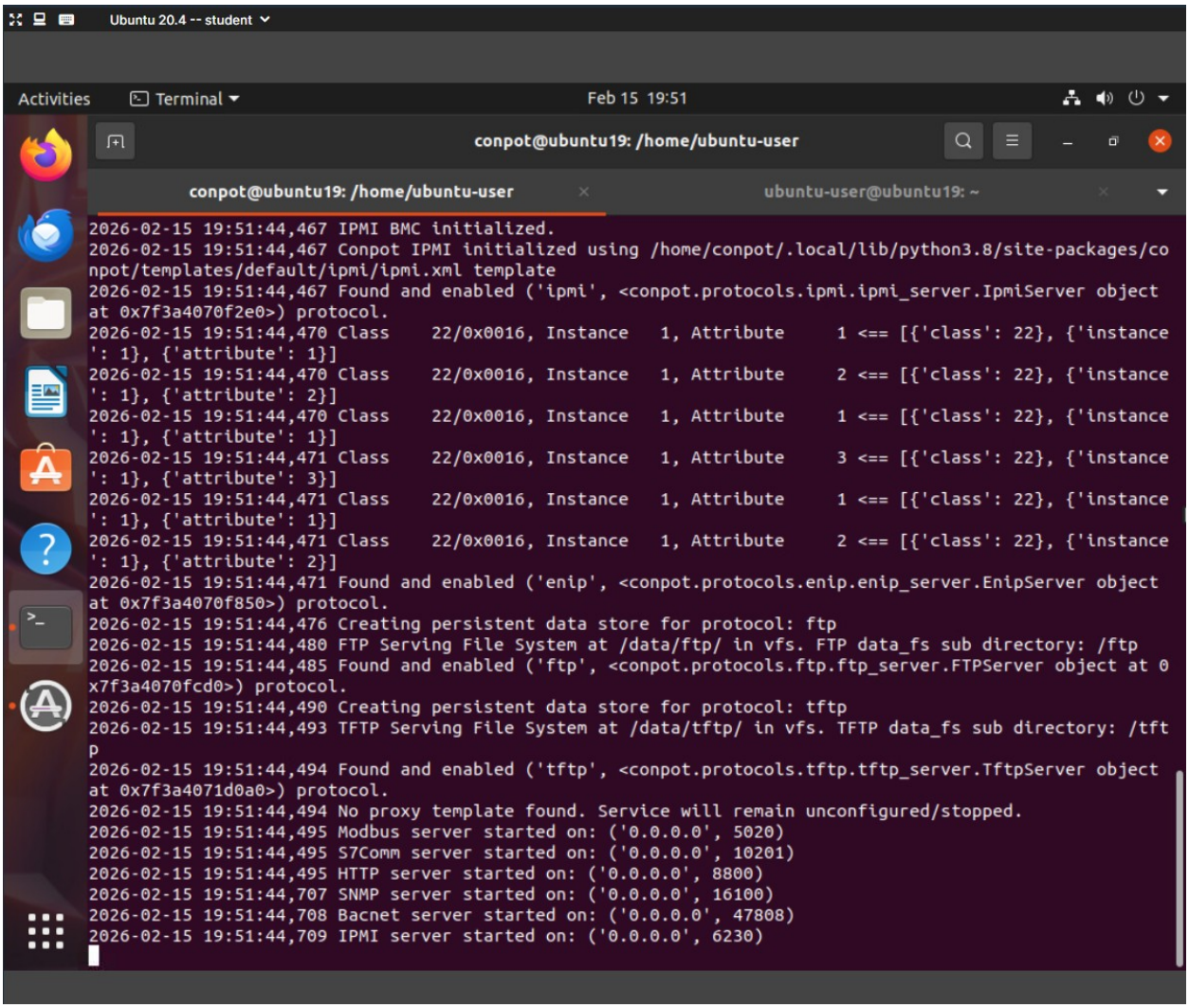
Firewall Rules for SCADA



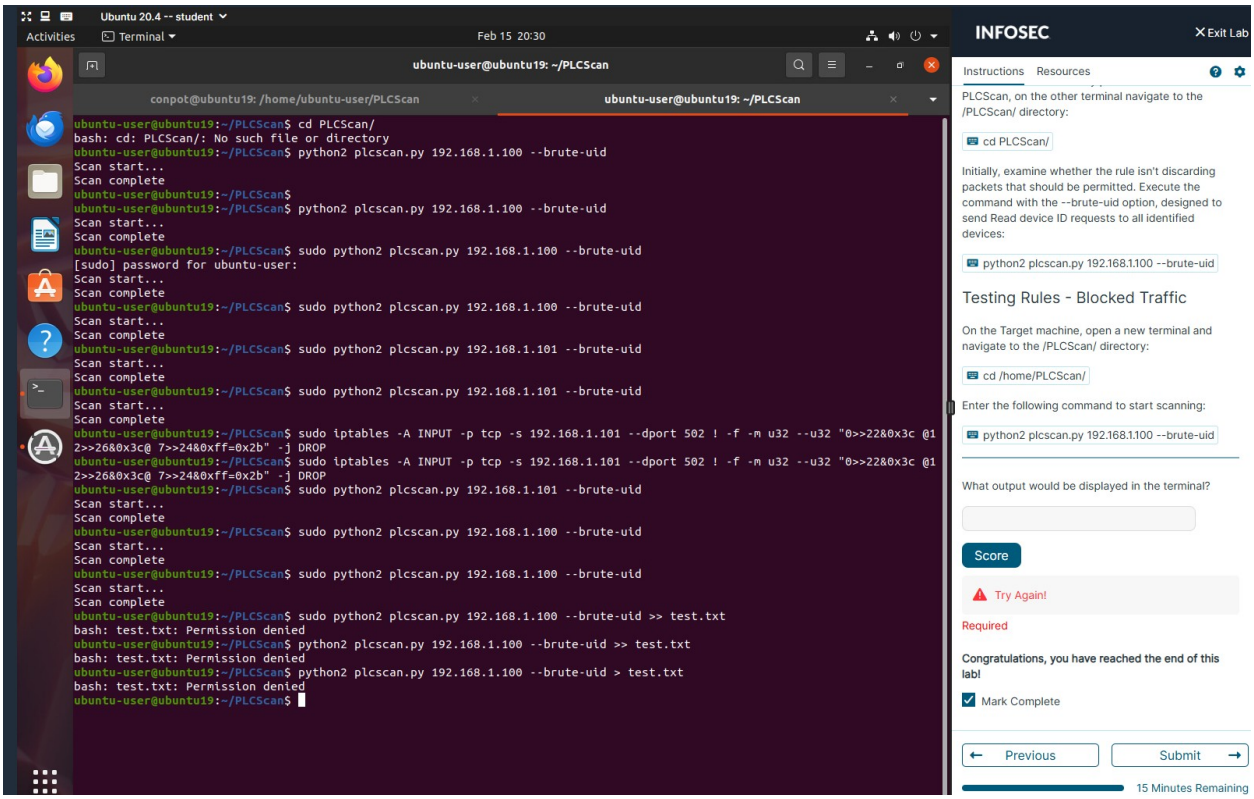
Selecting Packets: Outgoing Traffic

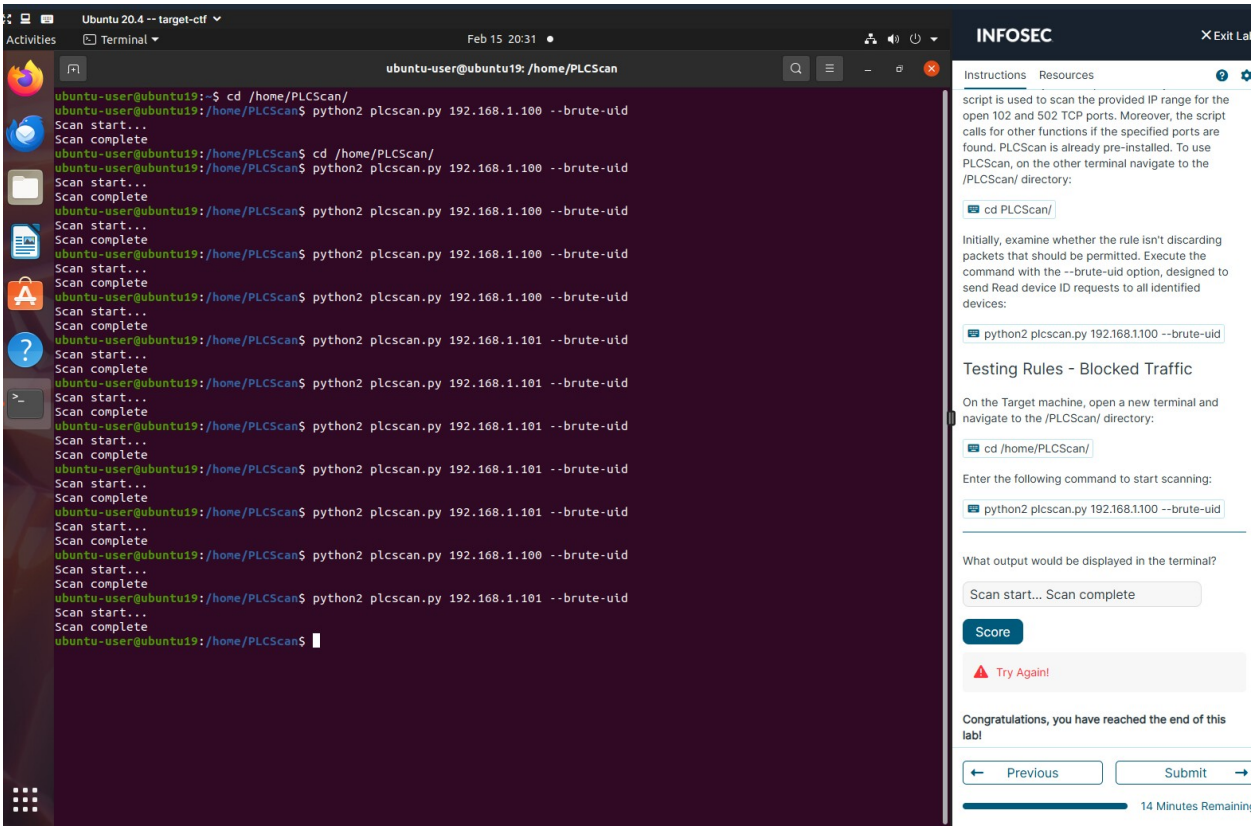


Starting Modbus Slave Simulator



Starting Conpot





Testing Rules - Allowed Traffic

(Could not figure out the output to mark as completed…)

4. References

Hadnagy, C. (2018). Social engineering: The science of human hacking (2nd ed.). Wiley.

Searle, J. (meeas). (n.d.). plcscan [Computer software]. GitHub. https://github.com/meeas/plcscan

Stouffer, K., Falco, J., & Scarfone, K. (2015). Guide to Industrial Control Systems (ICS) Security (NIST SP 800-82 Rev. 2). National Institute of Standards and Technology.

Verizon. (2023). 2023 Data Breach Investigations Report. Verizon Enterprise.